

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Managing Firewall Administrator Accounts

Unit 4 • Information Security 2 (10-151-111)



Learning Outcomes

By the end of this unit, you will be able to:



Describe authentication and authorization

Explain how PAN-OS separates proving identity from granting privilege, and name the objects behind each.



Create a local administrator account

Build a local user database entry, a Local Database Authentication Profile, and the administrator that uses them.



Create a non-local administrator account

Configure LDAP and RADIUS Server Profiles, Authentication Profiles, and an authentication sequence.



Assign privileges with admin roles

Apply dynamic roles and build custom Role-Based profiles that follow least privilege.



Configure non-interactive login

Set up certificate-based web access and SSH key access for administrators and automation.

LESSON 1

Accounts, Roles, and the AAA Model



Treat an Administrator Account Like a Toothbrush

It is personal, you do not share it, and it gets replaced on a schedule.

- The predefined `admin` account has full **superuser** access to everything. Fine for the first ten minutes of a deployment, a liability after that.
- Create a **separate account for each person** who needs administrative or reporting access — the vendor best practice, and the only way logging means anything.
- Shared accounts destroy **attribution**. "Changed by admin at 2:14 a.m." is not evidence.
- Individual accounts are **revocable** — remove one person without a password change that breaks five others and three scripts.



SECURITY FOCUS

Every administrative action is recorded: the System log captures the login, the Configuration log captures the change — both tied to the account that did it.

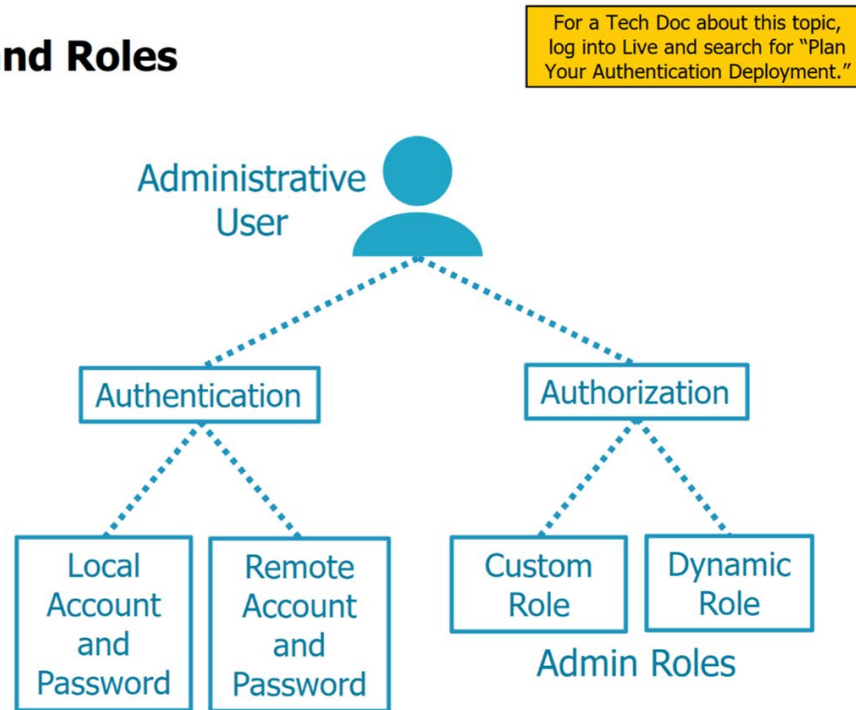
Why it matters: An audit trail built on a shared login is an audit trail of nobody.

Administrator Accounts and Roles

Two independent questions, answered by two different sets of objects:

Administrator Accounts and Roles

- The firewall can authenticate locally or remotely defined administrators.
- Each administrative account is assigned a role with specific privileges.
- Administrator actions are logged in the Configuration and System logs:
 - **Monitor > Logs**



The third A: accounting

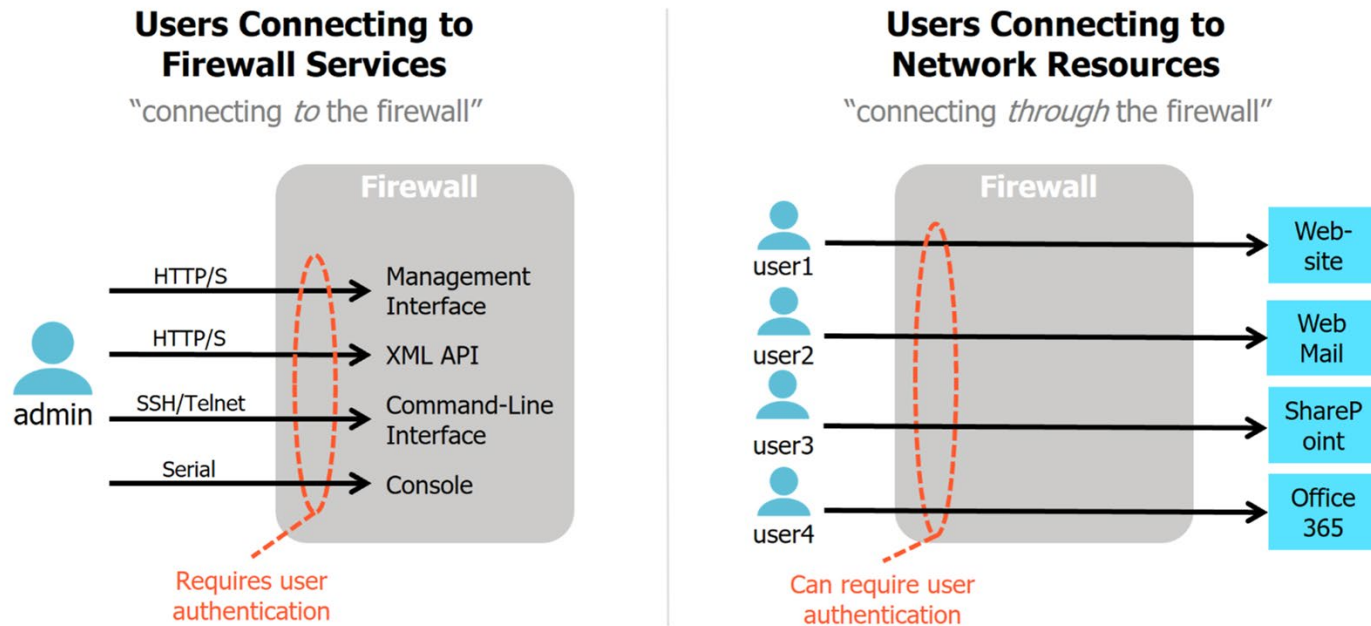
Authentication and authorization are configured. **Accounting is automatic** — you get it whether you plan for it or not.

Find it at **Monitor > Logs** — the System log for logins, the Configuration log for changes.

Adapted from Palo Alto Networks EDU-210-11 Module 04.

Authenticating "To" vs. "Through" the Firewall

The firewall authenticates users in two completely different scenarios:



Same profiles, same servers — different place you attach them.



Sort this out first

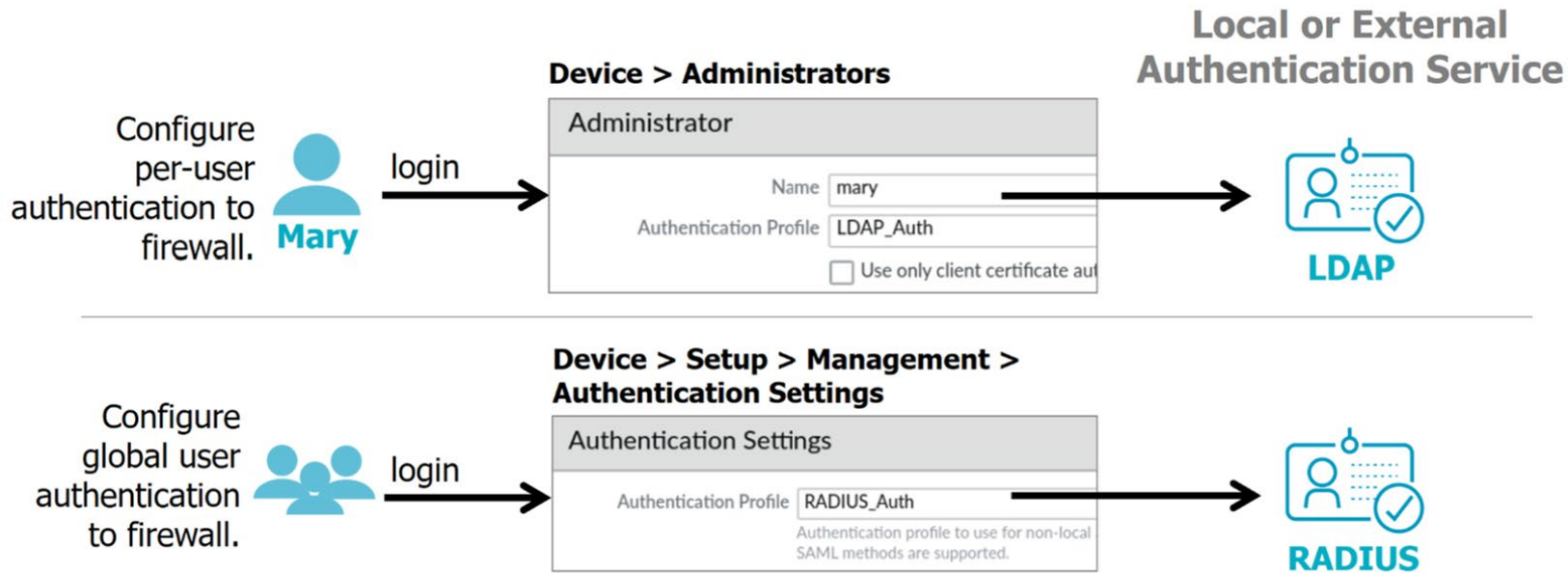
"To" the firewall = **administrators** reaching the web interface, CLI, API, or console. That is all of Unit 4.

"Through" the firewall = **end users** reaching network resources. That is Authentication policy, later in the course.

Where an Authentication Profile Attaches

Per-account or firewall-wide — the placement decides who it applies to:

The method used to authenticate users *to* the firewall depends on where you configure the user's Authentication Profile.

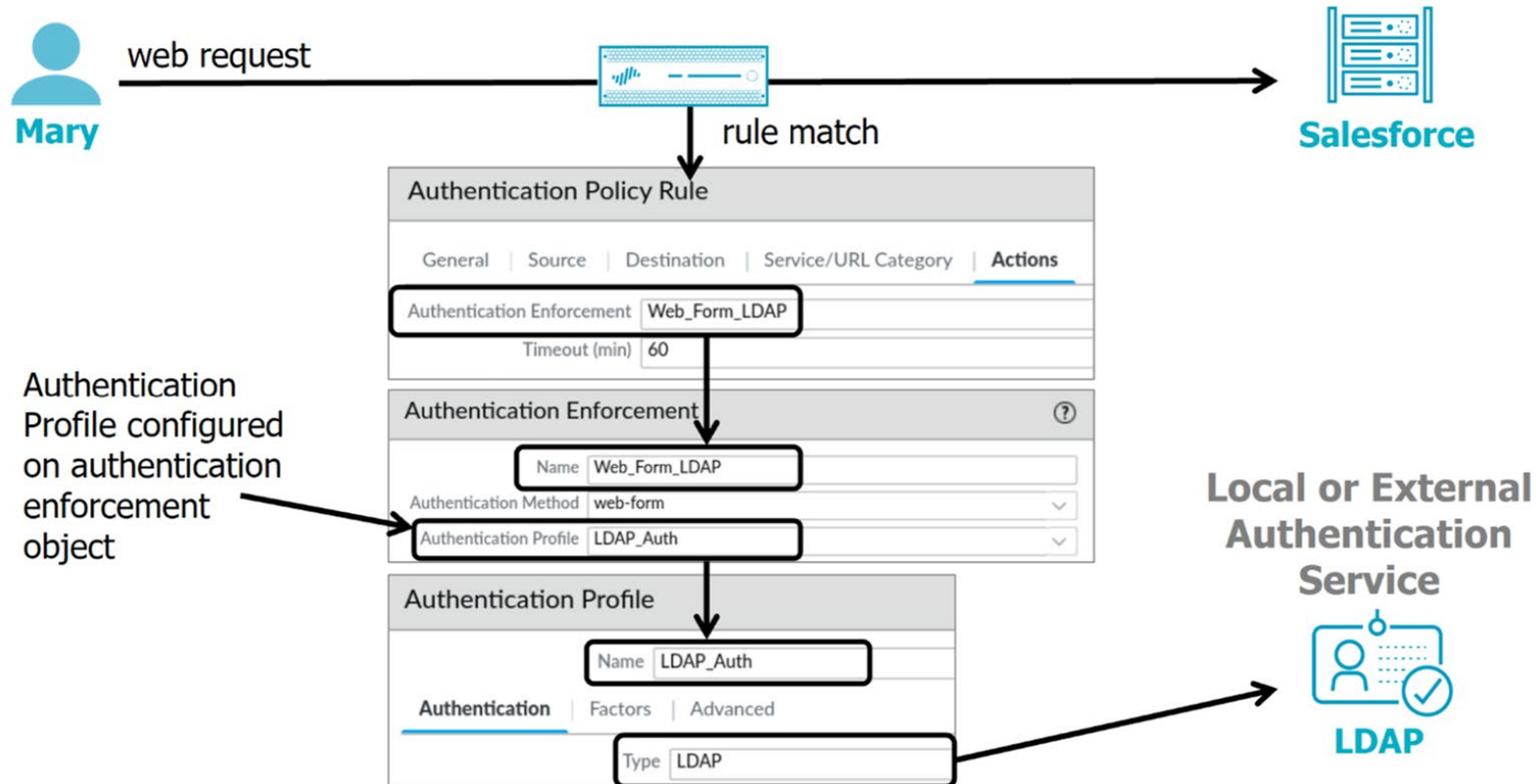


Supported only for RADIUS, TACACS+, and SAML

Global user authentication supports only RADIUS, TACACS+, and SAML — and SAML authenticates web-based access only.

Preview: Authenticating Users Through the Firewall

The same profile objects, hung off an Authentication policy rule instead of an account:



Covered later in the course — recognize the shape now and the configuration will feel familiar.

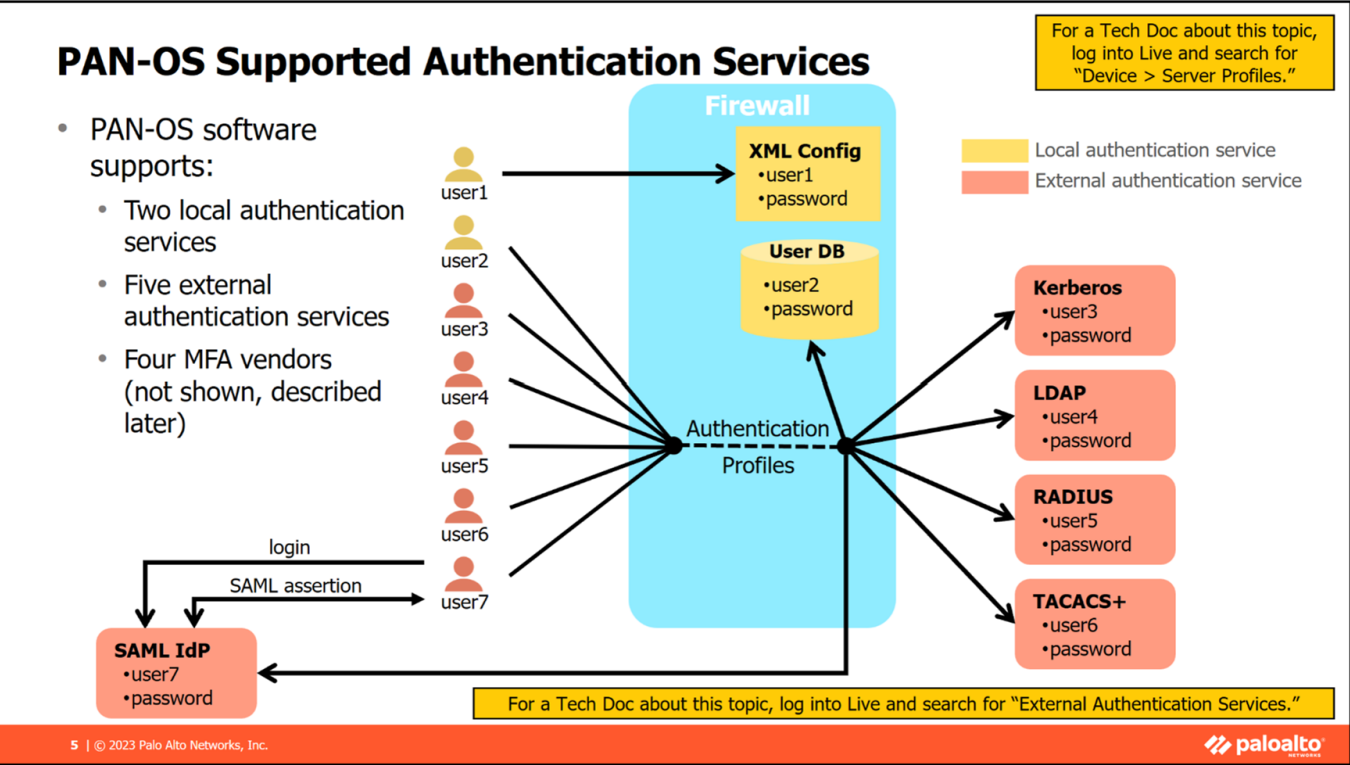
LESSON 2

The Authentication Services



PAN-OS Supported Authentication Services

Two local services, five external services, and MFA layered over the top:



The rule to carry forward

Every service except **local without a database** is reached through an **Authentication Profile**.

Only services that use a profile can authenticate **user traffic through the firewall** — not just logins to it.

External services additionally need a **Server Profile** to find the servers.

Local Authentication: Two Flavors

Local — no database

- Credentials live in the firewall **XML configuration file**
- No Authentication Profile involved — you type the password on the account
- Authenticates logins to the firewall only
- Fast to create; fine for a break-glass account

Local — user database

- `Device > Local User Database > Users`
- Reached through a **Local Database** Authentication Profile
- Authenticates firewall logins and traffic through the firewall
- Shared with Authentication Portal and GlobalProtect

Details that bite in the lab: usernames are case-sensitive, up to 31 characters, and the Enable checkbox must be selected or the account will not authenticate.

The Five External Services

All five authenticate both logins to the firewall and traffic through it:

Service	What it is	Worth knowing
LDAP	Directory lookup, including Active Directory	Needs base DN, bind DN, bind password
RADIUS	Classic network-device authentication	Usual integration point for MFA; VSAs can return roles
TACACS+	Separates authentication, authorization, accounting	Favored for device administration; VSAs can return roles
Kerberos	Ticket-based authentication against a realm	Basis for single sign-on with a keytab
SAML	Federated login to an identity provider	Web-based access only — cannot authenticate the CLI

A Server Profile can list several servers, so one unreachable directory server does not lock the whole team out.

Multi-Factor Authentication

Adds factors to the first one — it does not replace it.

- A **factor** is something you know, have, or are. MFA requires more than one before the login succeeds.
- PAN-OS integrates with supported MFA vendors, and also reaches MFA services through a **RADIUS Server Profile**.
- Configured on the **Factors** tab of an Authentication Profile — the tab you will skip past in the lab.
- Vendor guidance: enable MFA for **all management access**, using corporate credentials through RADIUS or SAML.



SECURITY FOCUS

A stolen or reused password is the most common way an attacker reaches a management interface. MFA is the control that survives the theft.

Why it matters: Password policy slows guessing; MFA stops a password that has already leaked.

LESSON 3

Authorization: Admin Role Profiles

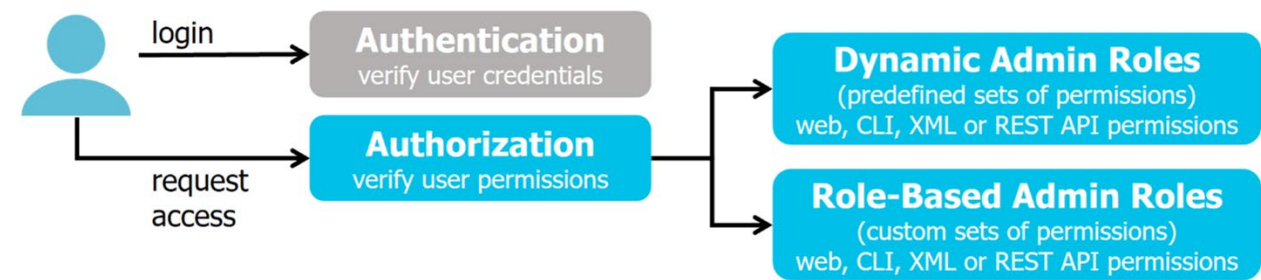


Authorization "To" and "Through" the Firewall

Managing the firewall is controlled by roles; reaching resources is controlled by policy:

User Authorization "to" and "Through" the Firewall

Authorization to manage the firewall controlled by Admin Role Profiles:



Authorization to access network resources *through* the firewall controlled by Security policy:

	NAME	TYPE	Source				Destination			APPLICATION	SERVICE	ACTION
			ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE			
1	Marketing-FB	universal	Users_Net	any	Marketing	any	Internet	any	any	facebook	application-default	Allow

↑ Must configure User-ID ↑



Two kinds of role

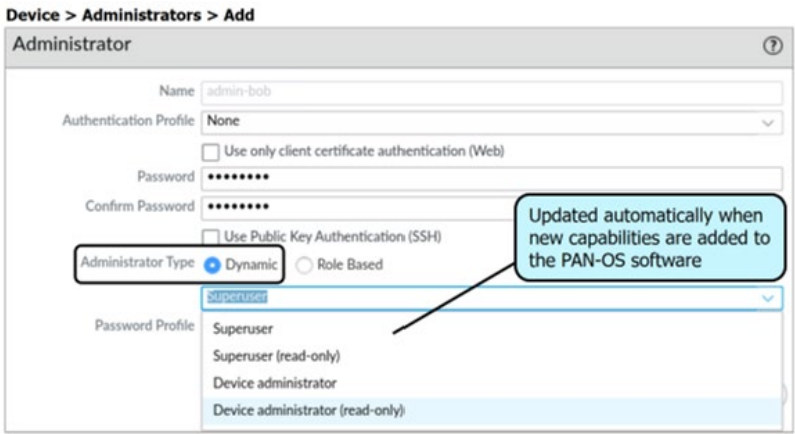
Dynamic — predefined, maintained by PAN-OS, updated automatically as features ship. Cannot be edited.

Role-Based — custom profiles you build at `Device > Admin Roles`, granular and yours to maintain.

The Six Dynamic Roles

Three scopes, each with a read-only twin:

Dynamic role	What it can do
Superuser	Everything, including creating accounts and virtual systems
Superuser (read-only)	Sees everything, changes nothing
Device administrator	All firewall settings except new accounts or virtual systems
Device admin (read-only)	Read-only, without visibility into other admin accounts
Virtual system admin	Assigned virtual systems only; no firewall or network functions
Vsys admin (read-only)	The same scope, read-only

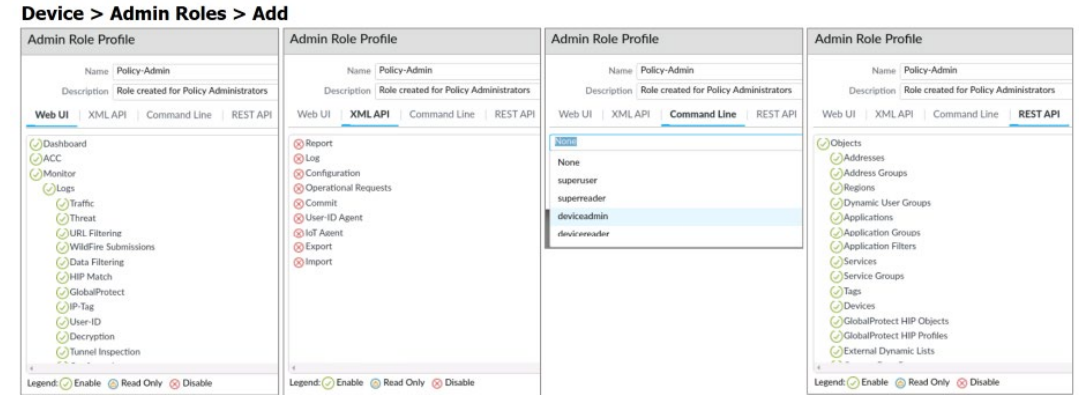


You must hold Superuser privileges to create another administrator with Superuser privileges.

Custom Role-Based Profiles

Built at Device > Admin Roles, with separate privileges per management interface:

- **Web UI** — enable, disable, or make read-only, node by node through the interface tree.
- **XML API** — which API operations the role may call: report, log, configuration, and more.
- **Command Line** — a single access level from a fixed list; no customization here.
- **REST API** — per-resource control over the REST interface.



Creating a Role-Based Role

Worked example

Operations get Network and Device areas with `deviceadmin` CLI. Security get policy, logs, and reports — and no Network at all.

Command Line Access Levels

Fixed values on the Command Line tab of a Role-Based profile:

Level	Access granted
None	No command-line access at all — the default, and the right answer for most accounts
superuser	Full access, including defining new administrator accounts and virtual systems
superreader	Read-only access to all options of the firewall
deviceadmin	Full access to all firewall settings except new accounts or virtual systems
devicereader	Read-only settings; no password profiles, and only the logged-in account is visible

Least privilege, concretely: if an administrator never uses SSH, set the Command Line level to None. An unused interface left enabled is attack surface nobody is watching.

LESSON 4

Building a Local Administrator Account



The Simplest Account: Local, No Database

Authentication Profile set to None — the password is stored in the firewall configuration:

Create a Local (Non-Database) Administrator Account

Device > Administrators > Add

Administrator

Name

Authentication Profile **None**

☐ Use only client certificate authentication (Web)

Password

Confirm Password

☐ Use Public Key Authentication (SSH)

Administrator Type ☒ Dynamic ☐ Role Based

Superuser

Password Profile **None**

Administrator Type dropdown menu:

- Dynamic
- Role Based

Profile dropdown menu:

- auditadmin
- cryptoadmin
- Policy-Admin
- securityadmin
- New Admin Role Profile

Superuser dropdown menu:

- Superuser
- Superuser (read-only)
- Device administrator
- Device administrator (read-only)

- Set the **Authentication Profile** to None and a password field appears.
- Assign either a **Dynamic** role or a **Role Based** profile — every account needs one.
- Set global rules at Device > Setup > Management > Minimum Password Complexity. By default there are none and passwords never age.
- A **Password Profile** overrides the global aging values for specific accounts.

Password complexity and Password Profiles apply to locally stored passwords only — not to accounts authenticated elsewhere.

Step 1: Add the User to the Local Database

Device > Local User Database > Users — the user store, not yet an administrator.

Create a User in the User Database

Device > Local User Database > Users > Add

Local User

Name: mary

Mode: ☒ Password ☐ Password Hash

Password:

Confirm Password:

☒ Enable

OK Cancel

Select **Password** and type the cleartext password.

Local User

Name: mary

Mode: ☐ Password ☒ Password Hash

.....

☒ Enable

OK Cancel

Select **Password Hash** and type or paste hashed password.

- Users can be created in the local database:
 - Not recommended if an external authentication service is available
- Users can be added as firewall administrators (**Device > Administrators**).
- Users can be used by the firewall to authenticate traffic flowing *through* the firewall.

For a Tech Doc about this topic, log into Live and search for "Device > Local User Database > Users."



Two modes, two use cases

Password — type and confirm a cleartext password. What the lab uses.

Password Hash — paste an existing hash, typically to reuse a Linux credential whose cleartext you do not know. Any string up to 63 characters.

A database user who is never added at **Device > Administrators** can authenticate traffic through the firewall, but cannot log in to it.

LIVE DEMO

Create the user live, leave *Enable* unchecked, and let the login fail before fixing it.

Step 2: The Local Database Authentication Profile

Device > Authentication Profile — links a username to the service that validates it.

Device > Authentication Profile > Add

Authentication Profile

Name LOCAL_Auth

Authentication Factors Advanced

Type Local Database

User Domain

Username Modifier %USERINPUT%

Single Sign On

Kerberos Realm

Kerberos Keytab Click "Import" to configure this field X Import

CAUTION: Allows any username with any password

None

Cloud Authentication Service

Local Database

RADIUS

LDAP

TACACS+

SAML

Kerberos

- Name the profile, then choose the **Type** — the remaining fields change with it.
- Select **Local Database** to point at the firewall user store.
- The lab profile is named `Local-Database`. Keep the name descriptive; you will pick it from a drop-down later.

Links a username to the authentication service that authenticates the user's credentials

Never select Type = None: it authenticates any username with any password. It exists for a handful of narrow scenarios, and yours is not one of them.

The Advanced Tab: Allow List and Lockout

Two controls that decide who may use this profile, and what happens when they guess:

Device > Authentication Profile

Authentication Profile

Name: LOCAL_Auth

Authentication: Factors **Advanced**

Allow List

☐ ALLOW LIST ^

☐ mary

☒ all

☐ Marketing

☐ mary

+ Add - Delete

Account Lockout

Failed Attempts: 3

Lockout Time (min): 10

Defines users or groups that can be authenticated by this profile

Specify **Account Lockout** settings for failed login attempts.

- **Allow List** — the users and groups this profile may authenticate. Leave it empty and **nobody** authenticates, with a configuration that looks perfectly correct.
- The lab uses `all`. In production, listing specific groups is a second, independent control on who reaches the firewall.
- **Failed Attempts** — consecutive failures before lockout, 0 to 10. The default of 0 means unlimited attempts.
- **Lockout Time (min)** — 0 to 60. A value of 0 locks the account until an administrator unlocks it manually.

A small Failed Attempts value with a short lockout frustrates guessing without turning every typo into a help desk ticket.

Step 3: Create the Administrator

Device > Administrators — the account that can actually log in.

Device > Administrators > Add

The screenshot shows the 'Add Administrator' configuration page. The form has the following fields and options:

- Name:** mary
- Authentication Profile:** LOCAL_Auth (dropdown menu)
- ☐ Use only client certificate authentication (Web)
- ☐ Use Public Key Authentication (SSH)
- Administrator Type:** ☐ Dynamic, ☒ Role Based
- Profile:** Policy-Admin (dropdown menu)

Two callout boxes provide instructions:

- One points to the 'Authentication Profile' dropdown: "Select or create an Authentication Profile (or authentication sequence)."
- Another points to the 'Profile' dropdown: "Select or create an Admin Role Profile."

- Enter the **same name** as the local database user — usernames are case-sensitive.
- Select the Authentication Profile, then a **Dynamic** role or a **Role Based** profile.
- No password field appears — the password lives in the local database, not on this object.
- **Commit**, then log out and log in as the new account to prove it works.

LIVE DEMO

Log in as the new account, then find the auth entry in Monitor > Logs > System.



LESSON 5

Non-Local Administrator Accounts

How the Firewall Authenticates a Non-Local Account

Server Profile finds the servers, Authentication Profile asks the question, the sequence sets the order:

Server Profile:

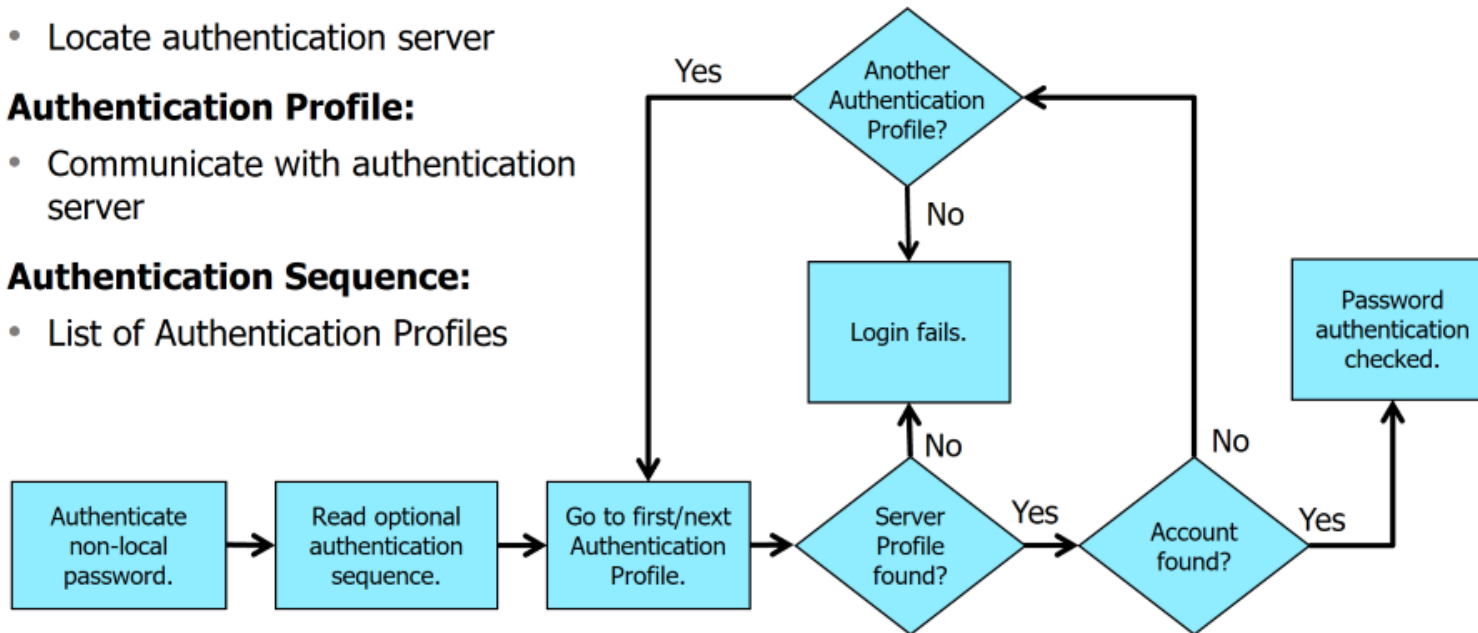
- Locate authentication server

Authentication Profile:

- Communicate with authentication server

Authentication Sequence:

- List of Authentication Profiles



Where is the password?

Local, no database — the firewall XML configuration.

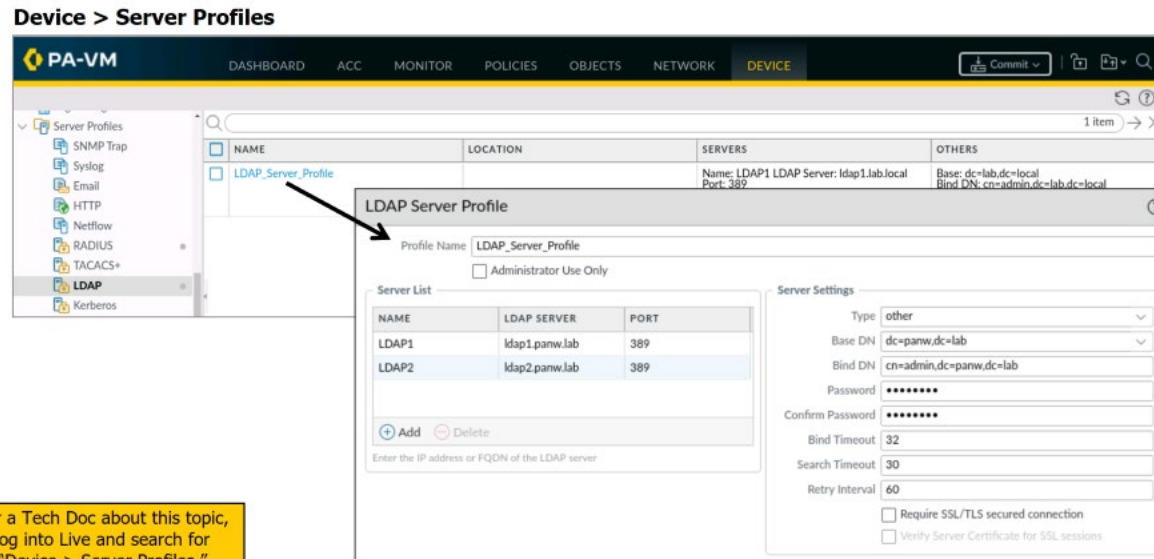
Local database — the firewall user store.

Non-local — an external server. The administrator object holds only the name and the role.

Most failed-login troubleshooting is just answering that question quickly.

Server Profiles

Device > Server Profiles — how the firewall finds RADIUS, TACACS+, LDAP, Kerberos, or SAML servers.



- **LDAP** — server address and port (389, or 636 for LDAPS), a **Base DN** that scopes the search, and a **Bind DN** and password the firewall uses to query.
- **RADIUS** — server address, port 1812, a shared secret, and an authentication protocol.
- List **more than one server** so a single unreachable server does not lock out the team.

For a Tech Doc about this topic, log into Live and search for "Device > Server Profiles."

CHAP in the lab only: the lab selects CHAP for simplicity. Production RADIUS should use PEAP or EAP-TTLS — the firewall itself will warn you in the System log.

Authentication Profiles for External Services

One profile per service, each pointing at the Server Profile you just built:

Device > Authentication Profiles

	NAME	LOCATION	Lockout	ALLOW LIST	AUTHENTICAT...	SERVER PROFILE	AUTHENTIC... FACTORS	OTHERS	LOCKED USERS
			FAILED ATTEMPTS (#)	LOCKOUT TIME (MIN)					
☐	LDAP_Auth		0	all	LDAP	LDAP_Server_Profile		Password Exp Msg: 7 days	none
☐	RADIUS_Auth		0	all	RADIUS	RADIUS_Server_Profile			none
☐	LOCAL_Auth		3	mary	Local				none

- Set the **Type** to LDAP or RADIUS, then choose the matching **Server Profile**.
- Set the **Allow List** on the Advanced tab again — it is per profile, and an empty list authenticates nobody.
- Lockout values are also per profile, so each service can have its own tolerance.

The list view is the fastest way to confirm every profile has an allow list and a server profile before you commit.

The Non-Local Administrator Account

Same dialog, no password — the external service maintains it:

Create a Non-Local Administrator Account

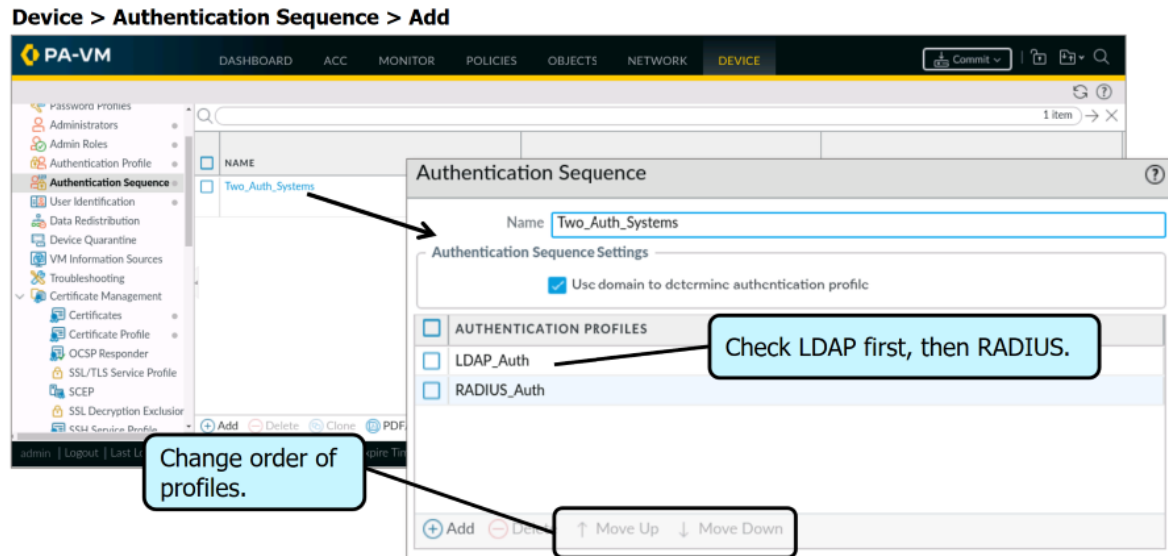
Device > Administrators > Add

- The **name must match** the account as it exists in LDAP or RADIUS.
- Select the Authentication Profile — or, once it exists, the **authentication sequence**.
- Assign the role here. Authentication tells the firewall **who**; only the role tells it **what**.
- The lab builds `adminSally` on LDAP and `adminHelga` on RADIUS.

Verify each one in Monitor > Logs > System — the auth entry names the profile and the server that answered.

Authentication Sequences

An ordered list of Authentication Profiles, tried until one succeeds:



SECURITY FOCUS

End the sequence with a local authentication profile. If every external service is unreachable, that local account is the only way back into the firewall.

Why it matters: Losing directory connectivity and firewall access in the same incident turns an outage into an emergency.

An account is denied only when every profile in the sequence fails to authenticate it.



LESSON 6

Non-Interactive Authentication

Interactive vs. Non-Interactive Authentication

Either the firewall prompts for a password, or a certificate answers for you:

Password Authentication (Interactive)



Certificate-Based Authentication (Non-Interactive)



Available only for web interface access



Where each one works

Client certificate — web interface only.

SSH public key — command line only.

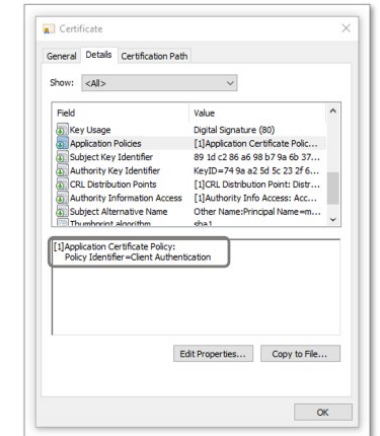
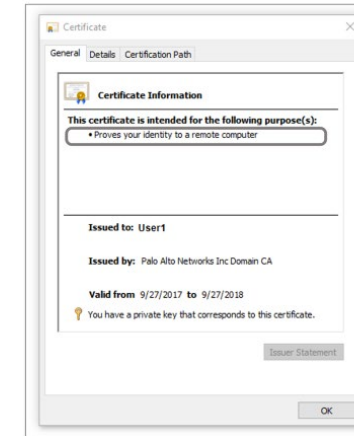
Neither sends a password across the network, which is the whole point.

Non-interactive login is what scripts and monitoring tools need — there is no human available to type anything.

Setting Up Certificate-Based Login

Five steps, in this order — the order is not optional:

- Generate or import a **CA certificate** on the firewall. Self-signed for the lab; your enterprise CA in production.
- Generate a **client certificate** for each administrator, signed by that CA.
- Export each certificate and **import it into the browser** on that administrator workstation.
- Build a **Certificate Profile** naming the CA to trust and the Username Field.
- Select the profile in `Device > Setup > Management > Authentication Settings`.



Read this twice: configuring certificate authentication for any administrator disables username and password login for every administrator on the firewall.

Certificate Profile: Trust and Revocation

Device > Certificate Management > Certificate Profile — which CAs to trust, and how to check revocation.

Device > Certificate Management > Certificate Profile > Add

Certificate Profile

NameWebUI-Client-Cert

Username FieldNone

User Domain

CA Certificates

	NAME	DEFAULT OCSP URL	OCSP VERIFY CERTIFICATE	TEMPLATE NAME/OID
☐	WebUI-CA			

CA certificate that signed client's certificate

Optional, but recommended, to enable client certificate revocation status checking

Default OCSP URL (must start with http:// or https://)

☒ Use CRL

CRL Receive Timeout (sec)5

☒ Use OCSP

OCSP Receive Timeout (sec)5

OCSP takes precedence over CRL

Certificate Status Timeout (sec)10

Apply blocking actions (optional).

☒ Block session if certificate status is unknown

☒ Block session if certificate status cannot be retrieved within timeout

☒ Block session if the certificate was not issued to the authenticating device

☒ Block sessions with expired certificates

Used by the firewall to verify the client's user certificate

- **OCSP** — asks a responder about one certificate and gets back good, revoked, or unknown.
- **CRL** — a published list of revoked serial numbers; works offline, only as current as the last publication.
- Enable both. The firewall tries OCSP first and falls back to the CRL after the status timeout.
- **Block session if status is unknown or cannot be retrieved** — fail-closed is the right default for management access.

The Username Field tells the firewall which certificate field identifies the account — Subject, in the usual configuration.

Turning It On

One firewall-wide setting, one checkbox per administrator:

Device > Setup > Management > Authentication Settings

Authentication Settings

Authentication Profile: None
Authentication profile to use for non-local admins. Only RADIUS, TACACS+ and SAML methods are supported.

Authentication Profile(Non-UI): None
Authentication Profile to use for non-UI like CLI and API

Certificate Profile: WebUI-Client-Cert

Idle Timeout (min): 60 (default)

API Key Lifetime (min): 0 (default)

API Keys Last Expired: Expire All API Keys

Failed Attempts: 0

Lockout Time (min): 0

Max Session Count (number): 0

Max Session Time (min): 0

OK Cancel

Used only for access through web interface, not CLI

Enables the firewall to verify client certificates using the Certificate Profile

Create an Administrator Account for Non-Interactive Login

Device > Administrators > Add

Administrator

Name:

☒ Use only client certificate authentication (Web)

☐ Use Public Key Authentication (SSH)

Administrator Type: ☐ Dynamic ☒ Role Based

Profile:

- Selection of the check box configures the firewall to perform certificate-based authentication:
 - Authenticates access only to the firewall web interface, not to the CLI
- No longer prompted for an Authentication Profile
- Still must authorize user actions by specifying an Admin Role Profile

Still required: a certificate proves identity only. The account still needs an Admin Role Profile, because authentication never grants authorization.

SSH Keys and Automation

The command-line equivalent, and the right pattern for anything unattended:

- Select **Use Public Key Authentication (SSH)** on the administrator account, then upload that user public key.
- The **private key never leaves** the workstation — there is no password crossing the network to capture or guess.
- Give every script and monitoring tool **its own account**, its own key, and a role limited to what it calls.
- Palo Alto Networks recommends a separate admin account dedicated to **API access** for exactly this reason.



SECURITY FOCUS

A script that logs in with the shared admin password puts full superuser rights in a text file on a server nobody is auditing.

Why it matters: Automation credentials leak quietly and get discovered loudly.

When Administrator Authentication Fails

A management plane is only as strong as the step that verifies the credential:



SECURITY FOCUS

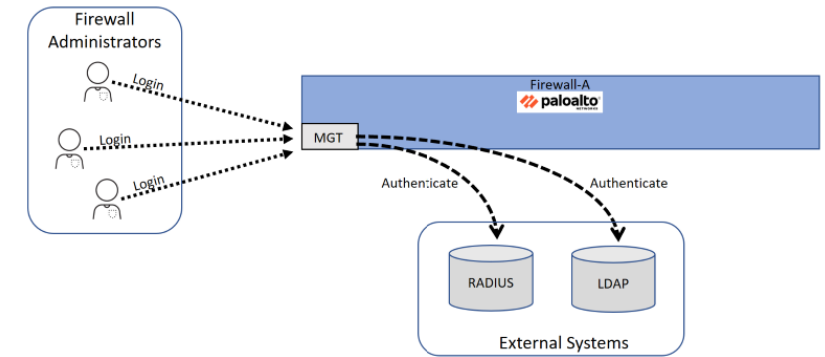
In CVE-2020-2021, when SAML authentication was enabled and "Validate Identity Provider Certificate" was left unchecked, PAN-OS verified signatures improperly. An unauthenticated attacker with network access to the web interface could log in as an administrator. CVSS base score: 10.0.

- The lesson is not "avoid SAML" — it is that one unchecked verification step **invalidates everything downstream**: roles, logs, policy.
- Restricting management access to **trusted internal addresses** — the Unit 2 work — limits the blast radius of an authentication flaw you do not yet know about.
- Replace the default `admin` account, require MFA, apply least privilege, and read the logs you are already generating.

Hands-On Lab: Managing Firewall Administrator Accounts

NETLAB+ · Lab 3 · PAN-OS 11.0 · credentials and values are in the lab guide tables

- Load and commit the baseline configuration.
- Create a Local Database Authentication Profile with the Allow List set to all.
- Add adminBob to the Local User Database and build an administrator account from it.
- Configure LDAP and RADIUS Server Profiles and their Authentication Profiles.
- Create the non-local accounts adminSally (LDAP) and adminHelga (RADIUS).
- Build the LDAP-then-RADIUS authentication sequence and commit.



Verify every login in Monitor > Logs > System — the auth entry names the profile and the server that answered.

Discussion: Which Service, Which Role?

For each scenario: name the authentication service, the admin role, and the log entry that proves it works.

Scenarios

- Two-person shop, one firewall, no directory server
- College with Active Directory and forty IT staff on three campuses
- Monitoring script pulling statistics through the API every five minutes

Harder scenarios

- Managed service provider whose technicians must never see client policy rules
- Auditor who needs configuration and log access for two weeks
- Break-glass account for the night every external service is down

Expect disagreement on the MSP case — that one is genuinely a design decision, not a lookup.

Key Takeaways



One account per person. Shared logins make the audit trail worthless.



Every service except local-without-a-database goes through an Authentication Profile.



Authentication says who you are; only the Admin Role Profile says what you may do.



Server Profile to Authentication Profile to sequence to administrator — and keep a local profile last.



Certificate login is web-only, and enabling it disables passwords for every administrator.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 4 · Managing Firewall Administrator Accounts